

Chapter 1 (23-51), chapter 2 (52-81 section 2.5 is excluded)

Up to page 35 read the book

Computer and Network Assets, with Examples of Threats pg. 35

- **Hardware:** A major threat to computer system hardware is the threat to availability (damage and theft). Hardware is the most vulnerable to attack and the least susceptible to automated controls.
- **Software:** A key threat to software is an attack on availability (delete, **alteration** and damage).
 - Data protection, user authentication, network security and file security.
- **Data:** Security concerns regarding data are availability (damage), secrecy (unauthorized reading of data file/ database and this area has been the subject of perhaps more research and effort than any other area of computer security) and integrity.
- **Communication Lines and Networks** Network security attacks can be classified as *passive attacks* and *active attacks*. A passive attack attempts to learn or make use of information from the system, but does not affect system resources. An active attack attempts to alter system resources or affect their operation.
 - Passive attack like **release of message contents** (easily understood like SMS and telephone conversation) and **traffic analysis** (determine the location, identity of host and length of message).
 - Active attack subdivided into **replay, masquerade, modification of messages and denial of service**.

Security functional requirements pg. 38

- **Access control:** limit information system access to authorized users.
- **Awareness and training:** ensuring that managers and users of organizational information systems are made of aware of the security risks and policies related to the security of organizational information systems. Ensure that personnel are trained to carry out security related duties.
- **Audit and accountability:** Create, protect, and retain information system audit records to enable the monitoring, analysis, investigation, and reporting of unauthorized information system activity. Ensure that the actions of users can be uniquely traced to those users so they can be held accountable for their actions.
- **Certification, Accreditation, and Security Assessments:** assess the security controls to determine if the controls are effective in their application. Develop and implement plans of action designed to correct deficiencies and reduce vulnerabilities in organizational information systems. Monitor information system security controls on an ongoing basis to ensure the continued effectiveness of the controls.
- **Configuration Management:** Establish and maintain baseline configurations and inventories of organizational information systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.
- **Contingency Planning:** Establish, maintain, and implement plans for emergency response, backup operations, and post disaster recovery for organizational information.
- **Identification and Authentication:** Identify users, processes acting on behalf of users, or devices, and authenticate (or verify) the identities of those users, processes, or devices, to allowing access to organizational information systems.
- **Incident Response:** Establish an operational incident-handling capability for organizational information systems that includes adequate preparation, detection, analysis, containment, recovery, and user-response activities.
- **Maintenance:** Perform periodic and timely maintenance on organizational information systems; and provide effective controls on the tools, techniques, mechanisms, and personnel used to conduct information system maintenance.

- **Media Protection:** Protect information system media, both paper and digital. Limit access to information on information system media to authorized users; and sanitize or destroy information system media before disposal or release for reuse.
- **Physical and Environmental Protection:** Limit physical access to information systems, equipment. Provide supporting utilities for information systems. Protect information systems against environmental hazards.
- **Planning:** Develop, document, periodically update, and implement security plans for organizational information systems.
- **Personnel Security:** Ensure that individuals occupying positions of responsibility within organizations (including third-party service providers) are trustworthy and meet established security criteria for those positions. Ensure that organizational information and information systems are protected during and after personnel actions such as terminations and transfers.
- **Risk Assessment:** Periodically assess the risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.
- **Systems and Services Acquisition:** Allocate sufficient resources to adequately protect organizational information systems. Employ software usage and installation restrictions; and ensure that third-party providers employ adequate security measures to protect information, applications, and/or services outsourced from the organization.
- **System and Communications Protection:** Monitor, control, and protect organizational communications (i.e., information transmitted or received by organizational information systems) at the external boundaries and key internal boundaries of the information systems; and employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational information systems.
- **System and Information Integrity:** Identify, report, and correct information and information system flaws in a timely manner; provide protection from malicious code at appropriate locations within organizational information systems; and monitor information system security alerts and advisories and take appropriate actions in response.

Fundamental security design principles pg. 39

- **Economy of mechanism:** security measure should be simple and small as possible, thus it will have fewer flaws and require less maintenance.
- **Fail-safe default:** access decisions should be based on permission rather than exclusion.
- **Complete mediation:** every access must be checked against the access control mechanism. System should not rely on access decisions retrieved from a cache.
- **Open design:** security mechanism's design should be open rather than secret. Encryption algorithm has to be open, but not encryption keys.
- **Separation of privilege:** a good example of this is multifactor user authentication.
- **Least privilege:** every process and user should operate using the least set of privileges necessary to perform the task using role based access control.
- **Least common mechanism:** the design should minimize the functions shared by different users.
- **Psychological acceptability:** security mechanism should not interfere with the work of users and at the same time meet the needs of those who authorize access.
- **Isolation:** public access systems should be isolated from critical resources (data and process).
- **Encapsulation:** data hiding.
- **Modularity:** developing a common module that can be invoked by numerous applications and protocols.
- **Layering (defense in depth):** refers to the use of multiple, overlapping protection approaches addressing the people, technology and operational aspects of information systems.

- **Least astonishment:** program or user interface should always respond in the way that is least likely to astonish the user.

Attack surfaces and attack trees pg. 43

- **Attack surfaces:** consists of the exploitable vulnerabilities in a system like open ports, SQL, web forms, interface, social engineering attack and services inside a firewall.
 - **Network attack surface** (network protocol vulnerabilities), **software attack surface** (web server software), and **human attack surface** (social engineering, human error and trusted insiders).
- **Attack trees:** represents a set of potential techniques for exploiting security vulnerabilities. The goal of an attack is represented as root node and leaf nodes represent different ways to initiate an attack.

Computer security strategy pg. 46

- **Specification/policy:** what is the security scheme supposed to do?
 - Value of the assets, vulnerabilities of the system, threat and likelihood of attacks.
- **Implementation/mechanisms:** how does it do it?
 - Prevention, detection, response and recovery.
- **Correctness/assurance:** does it work?
 - Assurance (does it meet the requirements and specifications and it's a degree of confidence), evaluation (testing a computer system with respect to criteria).
- **Standards organizations:** NIST, ISOC, ITU-T and ISO.

Chapter two: COMPUTER SECURITY TECHNOLOGY and PRINCIPLES 52-81 except 2.5

2.1 CONFIDENTIALITY WITH SYMMETRIC ENCRYPTION

- **Symmetric encryption/ conventional encryption/ single-key encryption:**
 - Data encryption standard (DES) and advanced encryption standard (AES) like rijndael are block encryption algorithms. **Strong algorithm** and **secret key** are needed.
 - **Plaintext:** original message or data that is fed into the algorithm as input.
 - **Encryption algorithm:** performs various substitutions and transformations on the plaintext.
 - **Secret key:** an input to the encryption algorithm. The exact substitutions and transformations performed by the algorithm depend on the key.
 - **Cipher text:** scrambled message produced as output. It depends on the plaintext and the secret key. For a given message, two different keys will produce two different cipher texts.
 - **Decryption algorithm:** encryption algorithm runs in reverse. It takes the cipher text and the secret key and produces the original plaintext.
 - **Cryptanalytic attacks:** rely on the nature of algorithm and knowledge of the general characteristics of the plaintext.
 - **Brute force attack:** trying every possible key on a piece of cipher text until plaintext is obtained.

	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

Key Size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/ μs	Time Required at 10^{13} decryptions/ μs
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	$2^{55} \mu s = 1.125$ years	1 hour
128	AES	$2^{128} \approx 3.4 \times 10^{38}$	$2^{127} \mu s = 5.3 \times 10^{21}$ years	5.3×10^{17} years
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	$2^{167} \mu s = 5.8 \times 10^{33}$ years	5.8×10^{29} years
192	AES	$2^{192} \approx 6.3 \times 10^{57}$	$2^{191} \mu s = 9.8 \times 10^{40}$ years	9.8×10^{36} years
256	AES	$2^{256} \approx 1.2 \times 10^{77}$	$2^{255} \mu s = 1.8 \times 10^{60}$ years	1.8×10^{56} years

- **Block cipher (Electronic codebook mode):** each block of plaintext is encrypted using the same key. It is reusable key.
- **Stream ciphers:** processes input one block of elements or one character at a time producing an output block for each input block. It is faster and uses less code

2.2 MESSAGE AUTHENTICATION AND HASH FUNCTIONS

Algorithm	Digital Signature	Symmetric Key Distribution	Encryption of Secret Keys
RSA	Yes	Yes	Yes
Diffie–Hellman	No	Yes	No
DSS	Yes	No	No
Elliptic Curve	Yes	Yes	Yes

- Protection against falsification of data and transactions attacks is known as **message or data authentication**.
- Data is authentic when it's genuine.
- **Message authentication using symmetric encryption:** $MAC_M = E(K_{AB}, M) \rightarrow$ send $MAC + M \rightarrow$ receiver split M AND $MAC \rightarrow E(M, K_{AB}) \rightarrow$ compare MAC_1 and MAC_2 .
- **One way hash function:** accepts a variable size message M as input and produces a fixed size message digest $H(M)$ as output. The length field is a security measure.
- **Message authentication using hash function:** $MD_M = H(M) \rightarrow$ send $MD + M \rightarrow$ receiver split M AND $MD \rightarrow H(M) \rightarrow$ compare MD_1 and MD_2 .
- **Message authentication using hash function and symmetric encryption:** $MD_M = H(M) \rightarrow MAC_M = E(K_{AB}, MD) \rightarrow$ send $MAC + M \rightarrow$ receiver split M AND $MAC \rightarrow H(M, K_{AB}) \rightarrow D(MAC_1, K_{AB}) \rightarrow$ compare MD_1 and MD_2 .
- **Digital signature** is used to ensure integrity, non-repudiation and authentication using sender's private key.

Read the book starting from page 64

Chapter 3 Access control

- **Authentication** is a process of verifying whether the credential of a subject is valid.
- **Discretionary access control** used by Linux based OS.
- **Labels on mandatory access control:** top secret $\rightarrow$ secret $\rightarrow$ confidential $\rightarrow$ classified $\rightarrow$ sensitive but unclassified $\rightarrow$ public.
- **Attribute based access control** is based on policy and attribute.
- **Attributes** like **subject attribute** like 'is it a human', **object attribute** like 'is it a hardware/software' and **environment attribute** like 'LAN, VPN, port and bandwidth'.

Chapter 4 Network security

- **Application layer** -> **data**: http/s, SMTP, FTP, **POP**, **IMAP**, DHCP and DNS. **Telnet (virtual terminal)** and **SSH or secure sockets shell**.
- **Presentation layer**: translation, compression and encryption. **SSL/TLS**
- **Session layer**: session establishment, authentication and authorization.
- **Transport layer** -> **segment/datagram**: TCP, UDP and port number.
- **Internet/network layer** -> **packet**: ICMP, IP, IGMP, path determination (EIGPR, BGP, OSPF and IS-IS) and routing. **IPsec**
- **Data access/ link layer** -> **frame**: Ethernet, switch and MAC address.
- **Physical**: bit, byte, cable, NIC and radio frequency.
- **Protocol data unit (PDU)** = payload + header + trailer.
- **MIME**: multipurpose internet mail extension. **RFC 822** defines a simple header used to route an e-mail.
- **DKIM** (domain keys identified mail) is a specification for cryptographically signing e-mail messages, permitting a signing domain to claim responsibility for a message in the mail stream. It's transparent.
- **MHS** (message handling service) → **MUA** (message user agent), **MSA** (mail submission agent) → **SMTP** → **MTA** (message transfer agent) → **MDA** (mail delivery agent) → **MS** (message store).
- **ADMD** (an administrative management domain) is an Internet e-mail provider.
- **Types of network attacks**: header based, protocol based, authentication based and traffic based vulnerability.
- User to user authentication, host to host between to network layer, host to user this allows the user to prove the identity of the host and user to host.
- **Spoofing** is a kind of authentication base attack.
- **DoS** is traffic base attack.

Chapter 5 Application and OS security

- **Software security issues**: SQL injection, OS command line and cross-site scripting.
- **Risk resource management**: buffer over flow.
- **Porous defenses**: lack of authentication and missing authorization.
- **Defensive programming** using handling program input and validating input.
- **OS security**: design time (mistake by developer) and run/implementation time (mistake by system admin).
- **Hardening**: configure user, group, and permission, configure resource, service management (remove unnecessary service, program and protocol), install/configure additional security control and patching.

Network attack

- **SYN flooding attack**:
 - ✓ Protocol based attack, used to create DoS and spoofed IP maybe used to achieve anonymity.
 - ✓ It can be prevented using SYN cookies and ASA to boost the firewall.
- **TCP reset attack**:
 - ✓ Killing a connection by sending TCP reset segments.
 - ✓ Protocol and authentication based attack.
- **TCP session hijacking**: protocol based attack as well as an authentication based attack.
- **ARP spoofing**:
 - ✓ Protocol and header base attack
- **Smurf DDoS**: ICMP is exploited. Protocol and header based attack.
- **Ping of death** is a kind of protocol and header based attack.

- **Domain hijacking:** not a protocol based type of attack.

TCP Segment Header Format

Bit #	0	7	8	15	16	23	24	31	
0	Source Port				Destination Port				
32	Sequence Number								
64	Acknowledgment Number								
96	Data Offset	Res	Flags			Window Size			
128	Header and Data Checksum				Urgent Pointer				
160...	Options								

UDP Datagram Header Format

Bit #	0	7	8	15	16	23	24	31
0	Source Port				Destination Port			
32	Length				Header and Data Checksum			

IPv4 Packet Header Format

Bit #	0	7	8	15	16	23	24	31
0	Version	IHL	DSCP	ECN	Total Length			
32	Identification				Flags	Fragment Offset		
64	Time to Live		Protocol		Header Checksum			
96	Source IP Address							
128	Destination IP Address							
160	Options (if IHL > 5)							

Ethernet (802.3) Frame Format

7 bytes	1 byte	6 bytes	6 bytes	2 bytes	42 to 1500 bytes	4 bytes	12 bytes
Preamble	Start of Frame Delimiter	Destination MAC Address	Source MAC Address	Type	Data (payload)	CRC	Inter-frame gap

For TCP/IP communications, the payload for a frame is a packet

WiFi (802.11) Frame Format

2 bytes	2 bytes	6 bytes	6 bytes	6 bytes	2 bytes	6 bytes	0 to 2312 bytes	4 bytes
Frame Control	Duration	MAC Address 1 (Destination)	MAC Address 2 (Source)	MAC Address 3 (Router)	Seq Control	MAC Address 4 (AP)	Data (payload)	CRC

From shared videos

- User → KDC (**Kerberos**) → server, the reason why we do not use this as we browse websites is because single KDC has to be trusted by all, key management, all users must be known to KDC, not scalable, KDC must be online, etc.
- To overcome the use of KDC A will send a message encrypted by s (secret/ session key). Secret key is encrypted by using B's public key. $S \leftarrow H(s \parallel \text{nonce})$. Nonce is generated by B to fix reply attack. A has to sign the message for real authentication.
- **Bell-lapadula confidentiality model: star property** (no write-down), **simple security** property (no read up) and **strong star property**.

FTP Data	TCP	20
FTP Control	TCP	21
SSH	TCP	22
Telnet	TCP	23
SMTP	TCP	25
DNS	TCP/UDP	53
DHCP	UDP	67, 68
TFTP	UDP	69
HTTP	TCP	80
HTTPS	TCP	443
POP3	TCP	110
SNMP	UDP	161